RÉPUBLIQUE DU CAMEROUN
Paix – Travail – Patrie
* * * * * * * *
UNIVERSITÉ DE YAOUNDÉ I
* * * * * * * * * * * *
ÉCOLE NATIONALE SUPÉRIEURE POLYTECHNIQUE DE YAOUNDÉ
* * * * * * * * * * * * * * * * *
DÉPARTEMENT DE GÉNIE INFORMATIQUE
* * * * * * * * * * * * * * * * * * * *

REPUBLIC OF CAMEROON
Peace – Work – Fatherland
* * * * * * * *
UNIVERSITY OF YAOUNDÉ I
* * * * * * * * * * * *
NATIONAL ADVANCED SCHOOL OF ENGINEERING OF YAOUNDÉ
* * * * * * * * * * * * * * * * *
DEPARTMENT OF COMPUTER ENGINEERING
* * * * * * * * * * * * * * * * * * * *

ANALYSE DE RISQUE, AUDIT ET GESTION DE CRISE

CHARTE DE GOUVERNANCE DE LIZBIZ

NOMS ET PRÉNOMS	MATRICULES	SPÉCIALITÉS
AYONMENE TIOBOU Varese	22P045	HN-4 CIN

EXAMINATEUR : M. MINKA

Année Académique : 2025/2026

1. Introduction

La présente Charte de Gouvernance de la Sécurité des Systèmes d'Information (SSI) est soumise au Comité de Direction de LiZbiZ dans le cadre d'une mission de conseil mandatée par la DSI. Elle répond à une nécessité urgente : l'entreprise, en forte croissance, ne dispose d'aucun cadre formalisé pour la sécurité de son système d'information, alors qu'elle gère des données personnelles clients, accepte des paiements par carte (PCI-DSS) et opère une logistique connectée (IoT) critique.

2. Définition du rôle du RSSI

Dans l'organigramme de cette entreprise, le RSSI doit être rattaché directement au président directeur général (PDG) et non à la DSI pour garantir l'indépendance nécessaire à l'exercice du rôle de contrôle et éviter le conflit d'intérêt actuel où la DSI cumule à la fois la responsabilité de productrice et de contrôleuse de la sécurité.

Le poste de RSSI est entièrement décrit dans le tableau suivant :

Table 1 – Fiche de poste du RSSI

ATTRIBUT DU POSTE	DÉTAIL
Intitulé du poste	Responsable de la sécurité des systèmes d'informations
Rattachement hiérarchique	Rattache directement à son supérieur hiérarchique le PDG et indépendant de la DSI
Rattachement fonctionnel	Travaille en collaboration étroite avec la DSI, DPO, DAF et le responsable logistique
Niveau d'autorité	Recommandation et alerte auprès du comité de direction, suspension d'accès à risque en cas d'incident critique
6*Missions	Définir, mettre à jour et faire valider la politique de sécurité du système d'information de LiZbiZ Assurer la conformité règlementaire, préparer et accompagner les audits interne et externe Conduire et maintenir l'analyse de risque, identifier les actifs critiques, les menaces et les scénarios d'attaque Former et sensibiliser l'ensemble des collaborateurs à la sécurité informatique, concevoir et animer des campagnes de sensibilisation Superviser la gestion des incidents de sécurité, coordonner la réponse en cas d'incident critique, piloter la cellule de crise si nécessaire Produire un tableau de bord sécurité mensuel, présenter l'état des risques au comité de direction, argumenter les investissements sécurité

3. Matrice RACI

La matrice RACI ci-dessous couvre l'intégralité du cycle de vie d'un incident critique, structuré en 5 phases conformément à la norme ISO 27035 :

- **Phase 1 — Préparation & Détection** : mise en place des outils et qualification initiale de l'alerte
- **Phase 2 — Activation & Confinement** : déclenchement de la cellule de crise, isolation des systèmes
- **Phase 3 — Traitement & Éradication** : investigation forensique, suppression de la menace, restauration
- **Phase 4 — Notification & Communication** : obligations légales (CNIL 72h), communication interne et externe
- **Phase 5 — RETEX & Amélioration continue** : analyse des causes racines, plan d'actions correctif

3.1. Matrice RACI détaillée

Table 2 – Matrice RACI pour la gestion des incidents de sécurité

Activité	PDG	DSI	RSSI	DPO	DAF	Resp. Logistique	Technicien SI
PHASE 1 : PRÉPARATION ET DÉTECTION							
Définir la politique de gestion des incidents	I	C	A	C	I	I	I
Maintenir les outils de détection (SIEM/SOC)	I	C	R	I	I	I	R
Maintenir les playbooks et runbooks d'incident	I	I	A	I	I	I	R
Réaliser les tests & exercices (Tabletop)	I	C	R	I	I	C	R
Recevoir & qualifier une alerte de sécurité	I	C	A	I	I	I	R
Classifier l'incident (mineur / critique)	I	C	A	C	I	I	I
PHASE 2 : ACTIVATION ET CONFINEMENT							
Décider de l'activation de la cellule de crise	A	C	R	I	C	I	I
Notifier la Direction Générale (PDG, DAF)	I	I	R	I	I	I	I
Confiner les systèmes affectés (isolation réseau)	I	C	A	I	I	I	R
Préserver les preuves forensiques (logs, images disque)	I	I	A	I	I	I	R
Activer le Plan de Continuité d'Activité (PCA)	A	R	C	I	C	R	R
Évaluer l'impact business (arrêt logistique, pertes CA)	I	C	C	I	A	R	I
PHASE 3 : TRAITEMENT ET ÉRADICATION							
Analyser les causes racines (investigation forensique)	I	I	A	I	I	I	R
Éradiquer la menace (malware, comptes compromis)	I	C	A	I	I	I	R
Mettre en œuvre les mesures correctives d'urgence	I	A	C	I	I	I	R
Vérifier l'intégrité des données après éradication	I	I	A	C	I	I	R
Restaurer les systèmes (PRA — site de secours)	I	A	C	I	I	R	R
PHASE 4 : NOTIFICATION ET COMMUNICATION							
Notifier la CNIL en cas de violation de données (72h)	I	I	C	A	I	I	I
Notifier les clients et partenaires affectés	A	I	C	R	C	I	I
Communiquer en interne (collaborateurs)	I	C	R	I	I	R	I
Gérer la communication externe / médias / presse	A	I	C	I	C	I	I
Tenir le registre des incidents (log officiel)	I	I	A	C	I	I	R
PHASE 5 : RETEX ET AMÉLIORATION CONTINUE							
Organiser le RETEX à chaud (Hotwash — J+1)	I	C	R	I	I	I	R
Rédiger le rapport RETEX complet (5 Pourquoi, Ishikawa)	I	I	R	C	I	I	R
Valider et approuver le rapport RETEX	A	C	R	I	I	I	I
Mettre à jour le Plan d'Action Sécurité (PAS)	I	C	A	C	I	I	R
Présenter les enseignements au CODIR	I	C	R	I	I	I	I
Décider du budget correctif (investissements sécurité)	A	C	C	I	R	I	I

Légende RACI —

- **R** : Responsible, Réalise la tâche
- **A** : Accountable, Décide et assume (1 seul)
- **C** : Consulted, Consulté avant décision
- **I** : Informed, Informé du résultat

4. Résumé de la charte

- **Principe d'indépendance** : Le RSSI rapporte directement au PDG — aucune subordination à la DSI
- **Principe de séparation des pouvoirs** : Qui crée les accès (DSI) ne valide pas la politique de sécurité (RSSI)
- **Principe de l'unique Accountable** : Un seul décideur (A) par activité dans le RACI — responsabilité claire et non partagée
- **Principe de transparence** : Le CODIR est informé de l'état des risques tous les trimestres au minimum
- **Principe d'amélioration continue (PDCA)** : Tout incident critique donne lieu à un RETEX formalisé dans les 10 jours

Validation

La présente charte est soumise pour validation au Comité de Direction de LiZbiZ.

Fait à Yaoundé, le 21 Mars 2026

Pour validation,
Le Président Directeur Général